

Phishing / credential-harvesting response

Phishing · **Medium** severity · SOC IR Playbook

Severity

Medium

Detection & Analysis

- **Confirm and scope the campaign** — Verify the reported email is malicious; search the mail gateway for other recipients and similar messages.
- **Extract IOCs** — Pull sender, URLs, attachment hashes; scan them (multi-engine) and check CTI.

Containment

- **Quarantine and block** — Quarantine the message tenant-wide, block sender/domain/URL at the gateway and proxy.
- **Handle clickers** — Identify who clicked/submitted; force password reset and revoke sessions for submitters.

Eradication

- **Remove artifacts** — Purge delivered copies, remove any dropped payloads, revoke malicious OAuth grants.

Recovery

- **Restore and monitor** — Re-enable accounts after reset; watch for follow-on logins from the harvested credentials.

Post-Incident

- **Awareness & lessons learned** — Brief the affected users, feed a phishing-simulation, document the timeline.